MACÍAS
SÁNCHEZ
CONSULTORES

KIT DE HERRAMIENTAS LOPDP · ECUADOR

Guía de uso para el Delegado de Protección de Datos

Metodología, siete herramientas paso a paso, gran escala, honorarios, abordaje al cliente, propuestas de evaluación y control, informe a la gerencia y normas ISO para el DPD en Ecuador.

Abg. Mariano X. Macías Sánchez
Consultor en Protección de Datos Personales · Matrícula profesional 09-2022-736

Versión 1.1 · noviembre de 2026
Uso profesional · material de apoyo

PRESENTACIÓN

Cómo usar esta guía

Esta guía acompaña al **Kit de herramientas LOPDP**: siete herramientas, cada una en versión documento (Word o Excel) y versión web interactiva, diseñadas para que el Delegado de Protección de Datos (DPD) en Ecuador diagnostique, documente, evalúe, adecue y controle el cumplimiento de la **Ley Orgánica de Protección de Datos Personales (LOPDP)**, su Reglamento General (RGLOPDP) y la normativa de la **Superintendencia de Protección de Datos Personales (SPDP)**.

Está escrita para usarse en la práctica: cada capítulo responde **qué herramienta usar, cuándo, cómo y por qué**, e incluye el lenguaje para explicárselo al cliente con precisión técnica y sin perderlo.

Si necesita…	Vaya a
Entender el kit de un vistazo	Capítulo 1
Repasar el marco normativo y el vocabulario técnico	Capítulo 2
Planificar una intervención completa	Capítulo 3
Preparar la primera reunión, la propuesta de evaluación o la de control	Capítulo 4
Fijar honorarios y emitir la proforma	Capítulo 4 y 6.7
Saber si un tratamiento es de gran escala y si el DPD es obligatorio	Capítulos 5 y 6.6
Identificar qué datos trata una empresa	Capítulo 5
Usar cada herramienta paso a paso	Capítulo 6
Explicar las áreas de tratamiento (RAT y madurez)	Capítulo 7
Presentar el informe a la gerencia	Capítulo 8
Mantener el cumplimiento en el tiempo	Capítulo 9
Decidir qué normas ISO conocer o implementar	Capítulo 10
Revisar recomendaciones para el ejercicio del DPD	Capítulo 11

ATENCIÓN

Las citas normativas de esta guía se tomaron de la matriz **BASE-LEGAL.md** del kit. Varias provienen de resúmenes profesionales y no del texto oficial: contrástelas con el Registro Oficial antes de emitir un criterio a un cliente. Las escalas, umbrales y ponderaciones que no provienen de la norma se identifican como **criterio propio**.

Contenido

El kit en una página 4

Marco de actuación del DPD en Ecuador 5

2.1 Las normas que usará todos los días 5

2.2 El principio que ordena todo: responsabilidad proactiva 5

2.3 Vocabulario técnico, explicado con claridad 6

Metodología de intervención 7

Abordaje al cliente y propuestas 9

4.1 Antes de la primera reunión 9

4.2 Guion de la primera reunión (30 minutos) . . . 9
4.3 Objeciones frecuentes . . . 9
4.4 Cómo presentar la propuesta de evaluación . . . 10
4.5 Cómo presentar la propuesta de control . . . 11
4.6 Cómo fijar los honorarios . . . 11

Cómo identificar los datos que trata una empresa . . . 13

5.1 Las estructuras de referencia . . . 13
5.2 Las ocho preguntas del inventario (NIST ID.IM-P) . . . 13
5.3 Método de levantamiento en seis pasos . . . 13

Las herramientas paso a paso . . . 15

6.1 Herramienta 05 · Nivel de madurez . . . 15
6.2 Herramienta 01 · Registro de actividades de tratamiento . . . 17
6.3 Herramienta 04 · Evaluación de impacto . . . 18
6.4 Herramienta 02 · Kit de plantillas . . . 20
6.5 Herramienta 03 · Kit de vulneraciones . . . 20
6.6 Herramienta 07 · Evaluación de gran escala . . . 21
6.7 Herramienta 06 · Calculadora de honorarios . . . 22

Áreas de tratamiento: cómo explicarlas . . . 24

7.1 Macroprocesos del RAT . . . 24
7.2 Dominios del diagnóstico de madurez . . . 24

El informe a la gerencia . . . 26

8.1 Estructura del informe de evaluación general . . . 26
8.2 Matriz de soportes . . . 26
8.3 La presentación oral (20 minutos) . . . 27
8.4 Carpeta de evidencias . . . 27

Control y mejora continua . . . 28

9.1 Indicadores para la gerencia . . . 28

Normas ISO para el ejercicio del DPD . . . 29

10.1 Indispensables para un buen ejercicio . . . 29
10.2 Recomendadas y según el caso . . . 29
10.3 Ruta de implementación sugerida . . . 30

Recomendaciones para el ejercicio del DPD en Ecuador . . . 31

Anexos . . . 32

Anexo A · Lista de verificación de la primera visita . . . 32
Anexo B · Guion de entrevista por área . . . 32
Anexo C · Puntos que el DPD debe verificar en el texto oficial . . . 32

CAPÍTULO 1

El kit en una página

Siete herramientas que siguen el orden natural de una intervención: se cotiza, se mide, se inventaría, se califica la escala, se evalúa el riesgo, se adecúa la documentación y se prepara la respuesta. Al año, se vuelve a medir.

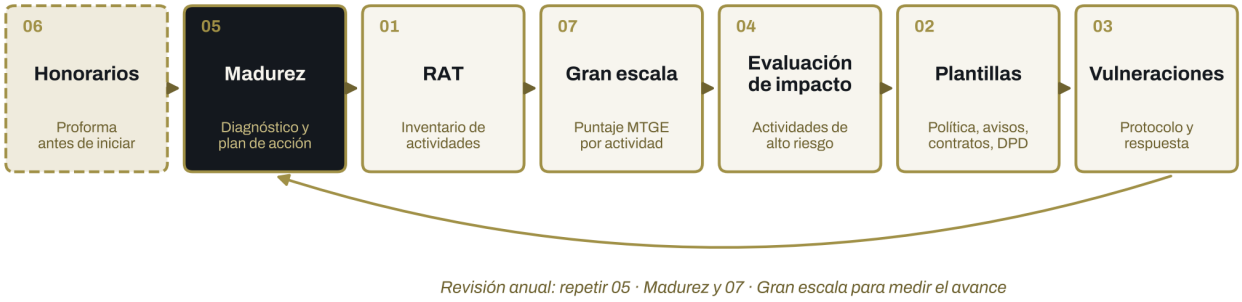


Figura 1. Orden de uso recomendado de las herramientas del kit.

Herramienta	Para qué sirve	Base principal	Entregable al cliente
05 · Nivel de madurez	Diagnosticar el cumplimiento, estimar la exposición económica y priorizar acciones	LOPDP arts. 10 lit. k y 47; Res. SPDP-SPD-2025-0022-R	Informe de diagnóstico con índice, radar, multa estimada y plan de acción
01 · Registro de actividades de tratamiento (RAT)	Inventariar cada actividad con el contenido mínimo legal	RGLOPDP arts. 38, 39 y 44	RAT en Excel con estados, riesgo y fechas de revisión
04 · Evaluación de impacto	Decidir si es obligatoria y evaluar riesgos y medidas antes de tratar	LOPDP art. 42; RGLOPDP arts. 29 a 32; Res. SPDP-SPD-2025-0003-R	Informe con el contenido del art. 32 RGLOPDP y matriz de riesgos
02 · Kit de plantillas	Cumplir el deber de información, formalizar encargados, consentimientos y DPD	LOPDP arts. 7, 12, 47, 48; RGLOPDP art. 41; Res. 0006 y 0028	Política, avisos, contratos de encargo, cláusulas, comunicaciones del DPD
03 · Kit de vulneraciones	Responder a incidentes y notificar en plazo	LOPDP art. 43; RGLOPDP arts. 24 a 28; Res. SPDP-SPD-2026-0040-R	Protocolo aprobado, bitácora y modelos de notificación
06 · Calculadora de honorarios	Estimar honorarios con tres métodos y emitir la proforma	Criterio propio; IVA (LRTI art. 65); Res. SPDP-SPD-2026-0005-R	Proforma con IVA, argumentos de valor y firma
07 · Evaluación de gran escala	Calificar cada tratamiento con el MTGE y decidir si el DPD y la evaluación de impacto son obligatorios	RGLOPDP art. 4 num. 7; Res. SPDP-SPD-2026-0005-R	Informe de gran escala con evidencia y columnas para el RAT

Cada herramienta tiene tres formas de uso: el **asistente web** (rápido, ideal en reunión con el cliente), el **documento editable** (Word o Excel, para el expediente) y el **código fuente** en el repositorio, que permite actualizar listas, preguntas y normas en un solo lugar.

BUENA PRÁCTICA

Use el asistente web en vivo durante las reuniones: el cliente ve cómo se construye el diagnóstico y entiende el porqué de cada recomendación. Luego copie el resultado a Word o Excel y archívelo con la firma de responsabilidad.

CAPÍTULO 2

Marco de actuación del DPD en Ecuador

El DPD no es un redactor de políticas: es quien asesora, vela y supervisa de forma independiente que la organización cumpla, y quien deja evidencia de ello.

2.1 Las normas que usará todos los días

Norma	Qué regula	Herramienta
LOPDP (RO Supl. 459, 26-05-2021)	Principios, bases legitimadoras, derechos, obligaciones, infracciones y sanciones	Todas
RGLOPDP (Decreto Ejecutivo 904, 2023)	RAT (arts. 38-44), evaluación de impacto (arts. 29-32), vulneraciones (arts. 24-28), contrato de encargo (art. 41)	01, 03, 04
Res. SPDP-SPD-2025-0003-R	Guía de Gestión de Riesgos y Evaluación de Impacto (Cap. I obligatorio; Cap. II referencial)	04, 05
Res. SPDP-SPD-2025-0006-R	Contenidos mínimos de cláusulas contractuales y modelos referenciales	02
Res. SPDP-SPD-2025-0022-R	Metodología de cálculo de multas (modelos MPRIV-1 y MPUB-1)	05
Res. SPDP-SPD-2025-0028-R	Figura del DPD, causales de designación obligatoria y registro	02, 05
Res. SPDP-SPD-2025-0041-R	Interés legítimo como base de legitimación	01, 04
Res. SPDP-SPD-2026-0004-R	Norma general de transferencias internacionales	01, 05
Res. SPDP-SPD-2026-0005-R	Tratamiento a gran escala: Modelo Técnico de Gran Escala (MTGE) y obligaciones reforzadas	06, 07
Res. SPDP-SPD-2026-0009-R y 0037-R	Protección de datos en sistemas de inteligencia artificial	04
Res. SPDP-SPD-2026-0039-R	Tratamiento de datos biométricos	04
Res. SPDP-SPD-2026-0040-R	Notificación de vulneraciones de seguridad (SISPDP)	03
Ley Orgánica para el Fortalecimiento de la Ciberseguridad (mayo 2026)	Reforma del art. 43 LOPDP: notificación también al CSIRT	03

2.2 El principio que ordena todo: responsabilidad proactiva

QUÉ DICE LA NORMA

El responsable debe **acreditar** haber implementado mecanismos para la protección de datos personales (LOPDP art. 10 lit. k). No basta con cumplir: hay que poder demostrarlo.

Por eso cada herramienta del kit produce un **soporte documental**: el RAT firmado, la evaluación de impacto fechada, la bitácora de incidentes, el contrato de encargo suscrito. Ante una inspección de la SPDP, la pregunta no será «¿cumple?», sino «¿cómo lo demuestra?».

2.3 Vocabulario técnico, explicado con claridad

Use siempre la terminología de la LOPDP. Evite los términos del reglamento europeo (interesado, brecha, AEPD) salvo para comparar. La columna derecha propone cómo explicarlo a un gerente.

Término	Definición técnica	Cómo explicarlo al cliente
Titular	Persona natural cuyos datos son objeto de tratamiento	La persona a quien pertenecen los datos: su cliente, su trabajador, su paciente
Responsable del tratamiento	Quien decide la finalidad y el modo del tratamiento	Su empresa, cuando decide para qué y cómo usa los datos
Encargado del tratamiento	Quien trata datos por cuenta del responsable	Su contador externo, su proveedor de nube o de nómina
Tratamiento	Cualquier operación sobre datos: recolección, registro, conservación, uso, comunicación, supresión	Todo lo que hace con un dato, desde pedirlo hasta borrarlo
Base legitimadora	Fundamento jurídico que hace lícito el tratamiento (art. 7 LOPDP)	La razón legal que le permite usar ese dato
Categorías especiales	Datos sensibles, de NNA, de salud y de personas con discapacidad (art. 25 LOPDP)	Datos que, mal usados, pueden discriminar o dañar gravemente
RAT	Registro de actividades de tratamiento (art. 38 RGLOPDP)	El inventario oficial de lo que hace con datos personales
Evaluación de impacto	Análisis previo de riesgos para los derechos de los titulares (art. 42 LOPDP)	El estudio de riesgo antes de lanzar un tratamiento delicado
Vulneración de la seguridad	Incidente que afecta confidencialidad, integridad o disponibilidad de los datos	Una fuga, pérdida o alteración de datos
Minimización	Tratar solo los datos adecuados, pertinentes y necesarios para la finalidad	Pedir solo lo que realmente necesita
Privacidad desde el diseño	Integrar la protección de datos desde la concepción de un proceso o sistema	Pensar en los datos antes de comprar o desarrollar, no después
Transferencia internacional	Envío o acceso a datos desde fuera del Ecuador	Cuando sus datos viven en un servidor en otro país

CAPÍTULO 3

Metodología de intervención

Una intervención ordenada evita el error más común: redactar políticas antes de saber qué datos trata la empresa.



Figura 2. Ciclo de intervención del DPD. Cada fase alimenta a la siguiente; el control reinicia el ciclo.

Fase	Objetivo	Herramienta	Entregable	Duración orientativa*
0. Propuesta	Cotizar el servicio	06 Honorarios	Proforma	1 a 3 días
1. Diagnóstico	Medir el punto de partida y la exposición	05 Madurez	Informe de diagnóstico	1 a 2 semanas
2. Inventario	Saber qué datos se tratan, dónde, para qué y con quién, y su escala	01 RAT · 07 Gran escala	RAT, mapa de flujos, informe de gran escala	2 a 6 semanas
3. Riesgos	Valorar riesgos y decidir medidas	04 Evaluación de impacto	Matriz e informes art. 32	1 a 3 semanas por tratamiento
4. Adecuación	Documentar y formalizar	02 Plantillas	Política, avisos, contratos, DPD	2 a 4 semanas
5. Respuesta	Estar listos para incidentes y solicitudes	03 Vulneraciones	Protocolo, bitácora, canal de derechos	1 a 2 semanas
6. Control	Sostener y medir	05 Madurez (repetición) · cap. 9	Reportes trimestrales e informe anual	Permanente

* Criterio propio para una pyme de 20 a 100 trabajadores. Depende del tamaño, el sector y la colaboración del cliente.

ERROR FRECUENTE

Empezar por la política de privacidad. Sin RAT no se sabe qué finalidades, bases ni plazos declarar: la política queda genérica y no protege a nadie.

CAPÍTULO 4

Abordaje al cliente y propuestas

El cliente no compra cumplimiento normativo: compra tranquilidad, reducción de riesgo y una respuesta clara ante la autoridad. El DPD debe traducir la norma a esos términos.

4.1 Antes de la primera reunión

- Identifique el **sector** y si trata categorías especiales (salud, educación, seguridad privada, financiero, biométricos).
- Estime el **tamaño**: con 100 o más trabajadores el RAT es obligatorio sin más análisis (art. 38 RGLOPDP).
- Revise su **sitio web**: formularios, política publicada, cookies, chat de WhatsApp. Suele ser la primera evidencia visible de incumplimiento.
- Verifique si la actividad está entre las causales de **designación obligatoria de DPD** (art. 10 Res. SPDP-SPD-2025-0028-R).
- Lleve abierto el **asistente de madurez** para responder en vivo.

4.2 Guion de la primera reunión (30 minutos)

1. **Apertura (3 min)**
   Presente el objetivo: entender cómo la empresa trata datos personales y mostrar su nivel de exposición. Aclare que no es una auditoría punitiva.
2. **Contexto del negocio (7 min)**
   Pregunte por procesos, no por datos: «¿Cómo llega un cliente nuevo? ¿Qué pasa cuando contratan a alguien? ¿Qué proveedores usan para facturar, nómina o correo?».
3. **Cinco preguntas clave (10 min)**
   ¿Tienen un listado de las bases de datos? ¿Quién decide cuánto tiempo se guardan? ¿Los proveedores firmaron cláusulas de protección de datos? ¿Qué harían mañana si les roban la laptop de contabilidad? ¿Alguien ha pedido que borren sus datos?
4. **Hallazgo inmediato (5 min)**
   Comparta un hallazgo concreto y verificable (por ejemplo, el formulario web sin aviso de privacidad). Genera confianza y urgencia sin alarmismo.
5. **Cierre (5 min)**
   Proponga el diagnóstico de madurez como primer paso acotado, con fecha de entrega y precio cerrado.

> **CÓMO DECIRLO AL CLIENTE**
> *«Su empresa trata datos personales todos los días: al facturar, al pagar la nómina, al grabar con sus cámaras. La ley no le prohíbe hacerlo; le exige poder demostrar que lo hace bien. En dos semanas le entrego un diagnóstico con su nivel de cumplimiento, cuánto podría costarle una sanción y qué hacer primero.»*

4.3 Objeciones frecuentes

El cliente dice…	Respuesta técnica y clara
«Somos pequeños, eso no nos aplica»	La LOPDP aplica a todo responsable, sin importar su tamaño. Con menos de 100 trabajadores, el RAT es obligatorio si el tratamiento no es ocasional, implica riesgo o incluye categorías especiales (art. 39 RGLOPDP). Tener un solo trabajador en nómina ya es un tratamiento habitual.
«Nadie ha sido sancionado todavía»	La SPDP ya publicó su metodología de cálculo de multas (Res. SPDP-SPD-2025-0022-R) y la notificación de vulneraciones es obligatoria. El diagnóstico le muestra su exposición en dólares, calculada sobre su propio volumen de negocio.
«Ya tenemos una política en la web»	La política es la última pieza, no la primera. Debe reflejar finalidades, bases y plazos reales, que salen del RAT. Una política genérica es una declaración sin respaldo.
«Eso lo ve el área de sistemas»	Sistemas protege la información; la protección de datos decide qué datos se pueden tratar, para qué y por cuánto tiempo. Son complementarios: el DPD trabaja con TI, no la reemplaza.
«Es muy caro»	Compare el costo del plan de adecuación con la multa estimada y el riesgo anual esperado del diagnóstico. La herramienta 05 hace esa comparación con números del propio cliente.

4.4 Cómo presentar la propuesta de evaluación

La propuesta de evaluación vende el **diagnóstico inicial**: un servicio acotado, con entregable claro, que abre la puerta a la adecuación. Estructura recomendada:

Sección	Contenido
1. Antecedentes	Lo que entendió del negocio en la reunión, en dos párrafos. Demuestra escucha.
2. Objetivo	Determinar el nivel de madurez en protección de datos, la exposición económica estimada y las acciones prioritarias.
3. Alcance	Entidad, sedes y procesos incluidos. Indique expresamente lo excluido (por ejemplo, auditoría técnica de seguridad).
4. Metodología	Entrevistas por área, revisión documental y aplicación de la herramienta de madurez (12 dominios, 39 criterios) y de la estimación de multa con la metodología de la SPDP.
5. Entregables	Informe de diagnóstico con índice de madurez, radar por dominio, multa estimada y apetito al riesgo, plan de acción priorizado; presentación a la gerencia.
6. Información requerida	Organigrama, listado de proveedores con acceso a datos, formularios y contratos tipo, ingresos del ejercicio anterior, persona de contacto por área.
7. Cronograma	Por semana: reunión de inicio, entrevistas, análisis, entrega y presentación.
8. Confidencialidad	Acuerdo de confidencialidad y, si accederá a datos personales del cliente, contrato de encargo (art. 41 RGLOPDP): el DPD externo también es encargado.
9. Honorarios y forma de pago	[HONORARIOS] · [FORMA DE PAGO] · vigencia de la oferta.
10. Próximo paso	Fecha de la reunión de inicio y firma.

BUENA PRÁCTICA

Limite la propuesta de evaluación a **dos páginas** y adjunte un ejemplo anonimizado del radar de madurez. El cliente decide por lo que ve.

4.5 Cómo presentar la propuesta de control

Tras la adecuación, la propuesta de control convierte el proyecto en un **servicio continuo**. Tres modalidades habituales:

Modalidad	Cuándo conviene	Incluye
DPD externo designado	La organización está obligada a designar DPD (Res. 0028) y no tiene perfil interno	Funciones del DPD, registro ante la SPDP, atención de derechos y vulneraciones, reportes
Acompañamiento de cumplimiento	Tiene responsable interno pero necesita soporte experto	Revisión trimestral del RAT, asesoría en proyectos nuevos, capacitación, simulacros
Revisión anual	Organización pequeña con riesgo bajo	Repetición del diagnóstico de madurez y actualización documental

La propuesta de control debe fijar **indicadores** (capítulo 9), la **frecuencia de reportes** a la gerencia, los **tiempos de respuesta** ante una vulneración (el encargado comunica al responsable en máximo 2 días y el responsable notifica a la SPDP en el término de 5 días) y los honorarios recurrentes.

CÓMO DECIRLO AL CLIENTE

«La adecuación deja la casa en orden; el control evita que se desordene. Cada trimestre le entrego un tablero con cinco indicadores y, si ocurre un incidente, ya sabemos quién hace qué y en qué plazo.»

4.6 Cómo fijar los honorarios

En Ecuador no existe una tabla oficial ni gremial de honorarios del DPD. La herramienta 06 propone tres miradas del mismo servicio y una regla de decisión. Todos los tramos y tarifas son **criterio propio**, ajustables a su mercado.

Método	Pregunta que responde	Úselo para
Volumen de negocio	¿Cuánto puede pagar este cliente?	Anclar el precio a su tamaño (COPCI: las ventas prevalecen sobre los trabajadores)
Volumen de tratamiento	¿Cuánto exige su tratamiento de datos?	Justificar el precio con el puntaje oficial MTGE de la SPDP
Estimación técnica	¿Cuánto cuesta mi tiempo?	Fijar el piso: nunca cotizar por debajo

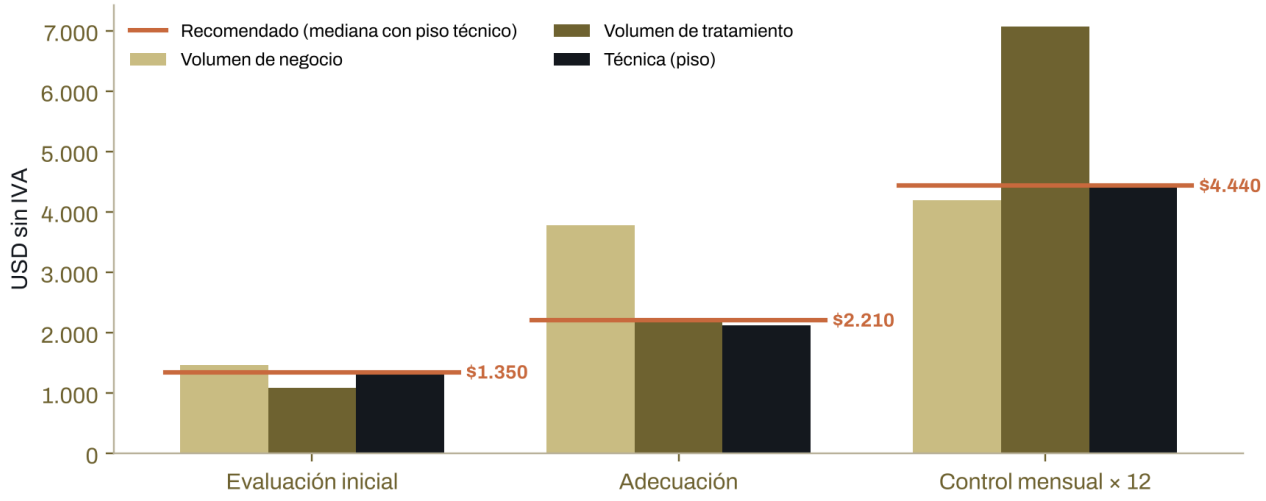


Figura 3. Honorarios del ejemplo ficticio por método (sin IVA). La recomendación es la mediana, nunca inferior al costo técnico.

BUENA PRÁCTICA

Si el cliente pide rebaja, reduzca el alcance antes que el precio. Si el volumen de negocio no cubre el costo técnico, ofrezca el paquete Esencial o cobro por evento. Presente los valores sin IVA y el total con IVA (15 %), separando el pago único del mensual.

CAPÍTULO 5

Cómo identificar los datos que trata una empresa

Sí existen estructuras reconocidas para hacerlo. La legal es el RAT; la técnica más difundida es el inventario y mapeo de datos del NIST Privacy Framework. El kit combina ambas.

5.1 Las estructuras de referencia

Estructura	Qué aporta	Cómo se usa en el kit
RAT (art. 38 RGLOPDP)	El contenido mínimo legal: finalidades, destinatarios, titulares, categorías de datos, perfiles, transferencias, bases, plazos y medidas	Herramienta 01: es el formato oficial del inventario
Registro Nacional de Protección de Datos (art. 51 LOPDP)	Inscripción de las bases de datos ante la autoridad	Dominio RAT de la herramienta 05
NIST Privacy Framework, categoría ID.IM-P (Inventario y mapeo)	Ocho subcategorías para levantar el inventario de forma sistemática (tabla 5.2)	Método de levantamiento del apartado 5.3
Modelo Técnico de Gran Escala (Res. SPDP-SPD-2026-0005-R)	Seis variables por tratamiento con umbral oficial; el cálculo debe constar en el RAT	Herramienta 07, una vez levantado el RAT
ISO/IEC 27701 e ISO/IEC 29100	Roles (titular, responsable, encargado), ciclo de vida del dato y registros de tratamiento dentro de un sistema de gestión	Vocabulario y estructura del capítulo 10

5.2 Las ocho preguntas del inventario (NIST ID.IM-P)

Subcategoría	Pregunta práctica	Columna del RAT
ID.IM-P1 Sistemas inventariados	¿Qué sistemas, aplicaciones y archivos físicos contienen datos personales?	Sistemas y soportes
ID.IM-P2 Propietarios y roles	¿Quién es dueño de cada sistema y qué rol tiene (responsable, encargado)?	Responsable interno · encargados
ID.IM-P3 Categorías de titulares	¿De quiénes son los datos?	Categorías de titulares
ID.IM-P4 Acciones sobre los datos	¿Qué se hace con ellos: recoger, consultar, comunicar, borrar?	Ciclo de vida · perfiles
ID.IM-P5 Finalidades	¿Para qué se usan?	Finalidades
ID.IM-P6 Elementos de datos	¿Qué datos exactamente?	Categorías de datos
ID.IM-P7 Entorno de tratamiento	¿Dónde se tratan: local, nube, terceros, otro país?	Transferencias · encargados
ID.IM-P8 Mapa del tratamiento	¿Cómo fluyen los datos de punta a punta?	Mapa de flujos (figura 3)

5.3 Método de levantamiento en seis pasos

1 **Mapa de procesos**

Pida el organigrama y liste los macroprocesos (capítulo 7). Cada macroproceso tendrá varias actividades de tratamiento.

2 **Entrevistas por área**

Una entrevista de 45 minutos por área con el guion del Anexo B. Pregunte por procesos y formularios, no por «bases de datos».

3 **Inventario de sistemas y soportes**

Liste ERP, nómina, CRM, correo, hojas de cálculo compartidas, WhatsApp corporativo, cámaras y archivo físico.

4 **Ciclo de vida por actividad**

Para cada actividad: recolección, almacenamiento, uso, comunicación, conservación y supresión.

5 **Mapa de flujos**

Dibuje origen, recolección, sistemas, encargados y destino. Marque en rojo las transferencias internacionales.

6 **Validación y registro**

Valide con el dueño de cada proceso y cargue el resultado en el RAT. Use el catálogo de actividades del asistente para no omitir las habituales. Después, puntúe cada actividad con la herramienta 07 (gran escala).

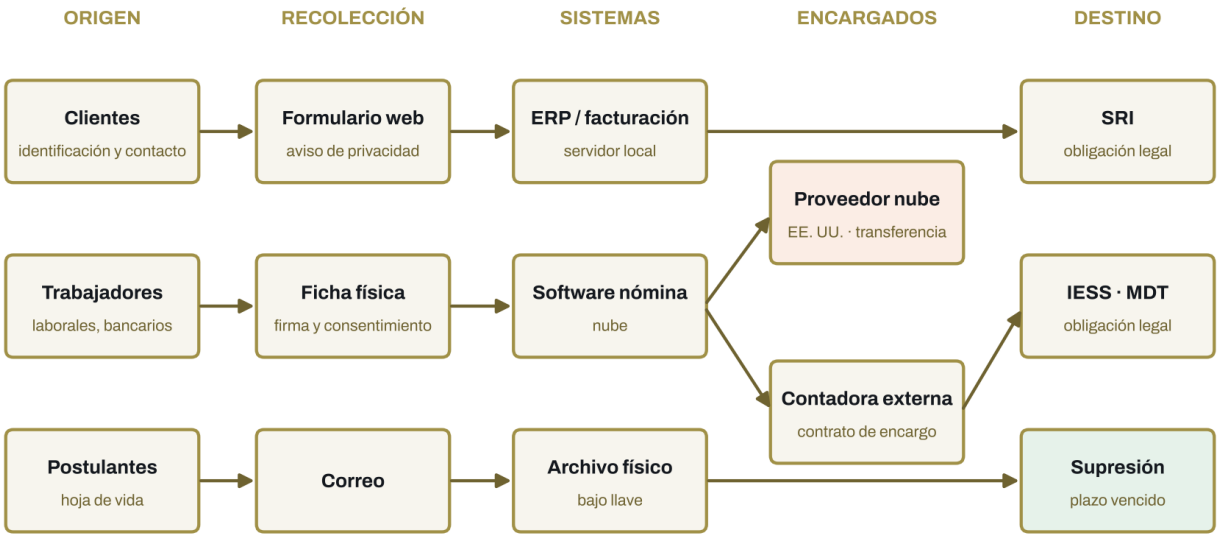


Figura 4. Ejemplo de mapa de flujos de datos de una pyme ficticia. La nube en EE. UU. revela una transferencia internacional que debe constar en el RAT.

ERROR FRECUENTE

Preguntar «¿qué bases de datos tienen?». La respuesta casi siempre es «solo la de clientes». Pregunte por procesos: así aparecen la nómina, las cámaras, el grupo de WhatsApp de ventas y las hojas de vida en el correo del gerente.

CAPÍTULO 6

Las herramientas paso a paso

Cada herramienta se presenta con la misma estructura: qué es, por qué es necesaria, cuándo usarla, cómo, un ejemplo, los soportes que genera, los errores frecuentes y cómo explicarla.

6.1 Herramienta 05 · Nivel de madurez

Qué es	Un diagnóstico de 39 preguntas en 12 dominios de obligaciones de la LOPDP, con índice ponderado de 0 a 4, radar por dominio, plan de acción priorizado y estimación de la multa con la metodología de la SPDP.
Por qué	Sin un punto de partida medible no hay plan defendible ni forma de demostrar avance (responsabilidad proactiva, art. 10 lit. k). Además, el reglamento de multas usa el grado de madurez en el cumplimiento como variable de cálculo.
Cuándo	En la primera visita, al inicio de cada año y antes de presentar resultados a la gerencia.
Entregable	Informe de diagnóstico (Word) y tabla de resultados (Excel).

Paso a paso

1. **Contexto**
   Registre organización, sector, número de trabajadores, fecha y personas entrevistadas.
2. **Cuestionario con evidencia**
   Puntúe de 0 (no existe) a 4 (gestionado). Exija evidencia: si no hay documento, no es 3. Use N/A solo si el punto no aplica, y justifíquelo.
3. **Resultados**
   Lea el índice ponderado (los dominios críticos pesan el doble), el radar y el plan de acción. Cada carencia indica la herramienta que la cierra.
4. **Impacto económico**
   Ingrese los ingresos por ventas del ejercicio anterior, la categoría de infracción a simular y la seriedad (afectación, intencionalidad, reincidencia). El asistente calcula la multa sin acción y con plan.
5. **Apetito al riesgo**
   Pida a la gerencia su capacidad de pérdida y su tolerancia. El asistente indica si la multa estimada está dentro o fuera del apetito.
6. **Informe**
   Copie el informe a Word, revise los textos y firme.

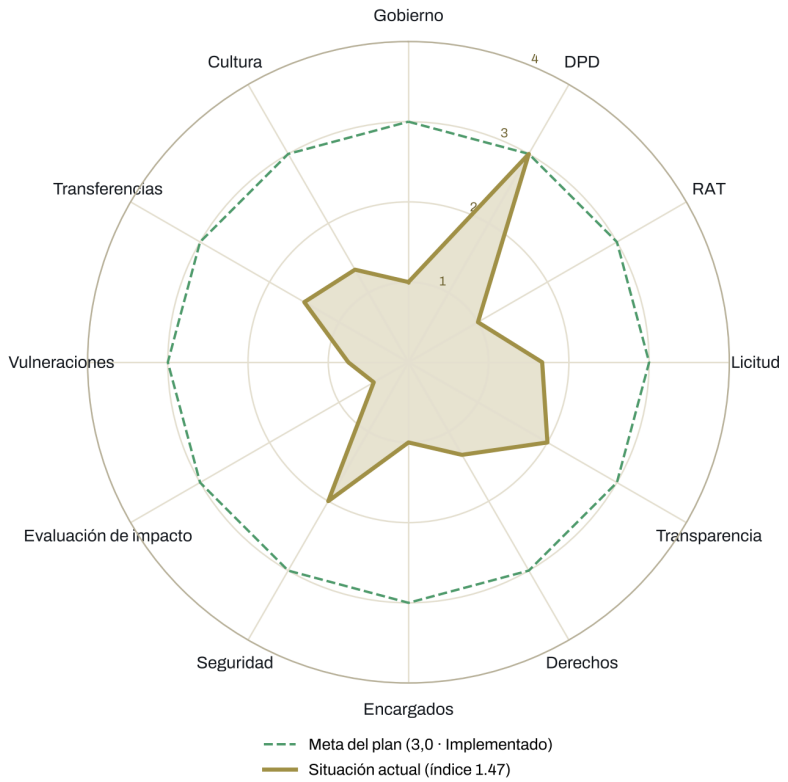


Figura 5. Radar de madurez del ejemplo ficticio (índice 1,47, nivel Inicial) frente a la meta del plan (3,0).

Nivel	Índice	Lectura para la gerencia
Inexistente	0 a 0,99	No ha iniciado la adecuación. Exposición alta.
Inicial	1 a 1,99	Acciones aisladas; faltan documentos básicos exigidos por la LOPDP.
En desarrollo	2 a 2,79	Documentos clave existen, pero incompletos o sin aplicación sistemática.
Implementado	2,8 a 3,49	Cumplimiento documentado y aplicado; falta medir y mejorar.
Gestionado	3,5 a 4	Cumplimiento sostenido, medido y revisado.

La estimación de la multa

La herramienta aplica el modelo **MPRIV-1** de la Res. SPDP-SPD-2025-0022-R sobre el **volumen de negocio del ejercicio económico anterior**: ingresos por venta de bienes y prestación de servicios, previa deducción de los impuestos directamente relacionados (LOPDP arts. 71 a 73). Las infracciones leves van de 0,1 % a 0,7 % del volumen de negocio y las graves de 0,7 % a 1 %.

Variable	Qué mide	Cómo la obtiene la herramienta
VDN	Volumen de negocio del ejercicio anterior	Ingresos menos impuestos relacionados, informados por el cliente (estados financieros o declaración de impuesto a la renta)
RDM	Rango legal de la categoría	Leve 0,1 %-0,7 %; grave 0,7 %-1 %
PDI	Grado de madurez en el cumplimiento (0-100 %)	Interpretación del portafolio: (1 – índice / 4) × 100
CDI	Categoría de la infracción	VDN × RDMmín + (PDI/100) × VDN × (RDMmáx – RDMmín)
SDI	Seriedad: afectación (60 %), intencionalidad (40 %), reincidencia (20 %)	2 × (0,6 IED + 0,4 INT + 0,2 RER), con estimación PERT de cada factor
Multa	Monto estimado	CDI × SDI, acotada al mínimo y máximo legal

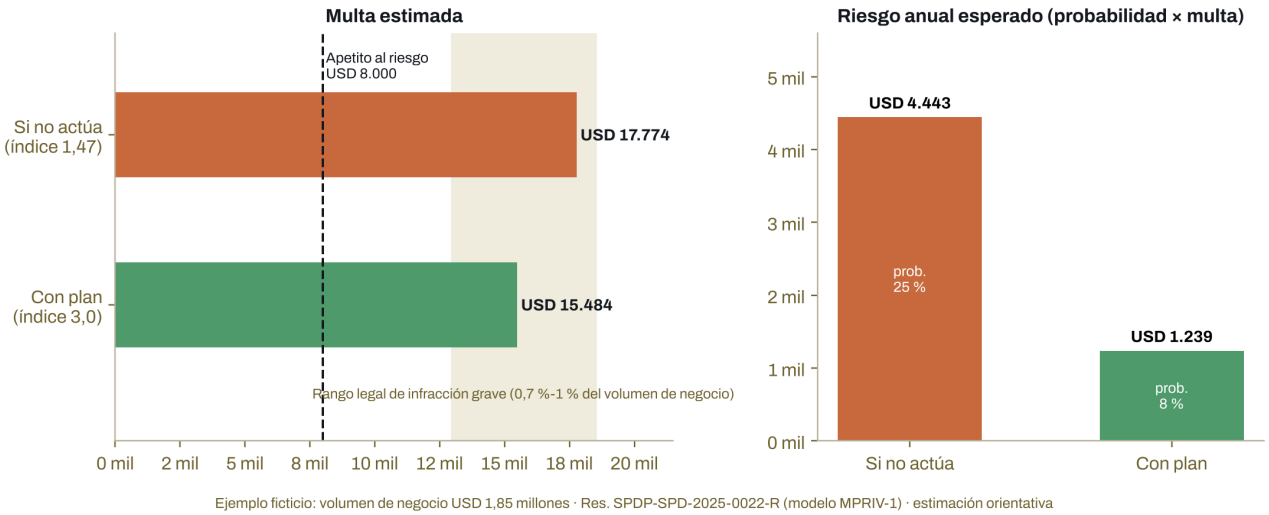


Figura 6. Multa estimada y riesgo anual esperado del ejemplo ficticio, sin acción y con plan, frente al apetito al riesgo.

ATENCIÓN

Es una **estimación orientativa**, no una liquidación. Las fórmulas provienen de un resumen profesional de la resolución; el sentido del PDI y la aplicación de los pesos son interpretación del portafolio. La SPDP fija los valores con sus propios fundamentos y puede usar un cálculo estocástico. No calcula multas del sector público.

CÓMO DECIRLO AL CLIENTE

«Con sus ingresos del año pasado, una infracción grave podría costarle alrededor de 17 mil dólares; su tolerancia es de 8 mil. El plan de adecuación cuesta menos que la multa y reduce el riesgo anual esperado de unos 4.400 a unos 1.200 dólares.»

ERROR FRECUENTE

Inflar los puntajes por cortesía con el cliente. El diagnóstico pierde valor como evidencia y el plan queda mal priorizado. Puntúe según evidencia y explique por qué.

6.2 Herramienta 01 · Registro de actividades de tratamiento

Qué es	Plantilla Excel y asistente web para documentar cada actividad con el contenido mínimo del art. 38 RGLOPDP, más buenas prácticas, con control automático del estado y del riesgo.
Por qué	Es obligatorio con 100 o más trabajadores, y con menos cuando el tratamiento implica riesgo, no es ocasional o incluye categorías especiales (arts. 38 y 39 RGLOPDP). Es la base de la política, los contratos y la evaluación de impacto.
Cuándo	Después del diagnóstico, y ante cada evento que cambie el tratamiento (proveedor nuevo, cambio de finalidad, sistema nuevo, vulneración).
Entregable	RAT en Excel firmado, con hoja del responsable y, si aplica, hoja del encargado (art. 44 RGLOPDP).

Paso a paso

1 **¿Está obligada?**

Responda las 16 preguntas de la pestaña de obligatoriedad; cada una tiene su ayuda normativa.

2 **Una actividad por fila**

Una actividad es un conjunto de operaciones con una misma finalidad y base. Nómina y publicidad son actividades distintas.

3 **Use el catálogo**
Elegir una actividad del catálogo (nómina, videovigilancia, facturación…) sugiere finalidades, datos y bases habituales que el DPD valida.

4 **Complete el mínimo legal**
Hasta que los nueve elementos del art. 38 estén completos, el estado es «Incompleto».

5 **Atienda las observaciones**
Las buenas prácticas (sistemas, volumen, contrato de encargo, evaluación de impacto) llevan la actividad a «Completo».

6 **Programe la revisión**
La fecha de revisión y el motivo de actualización dejan trazabilidad.

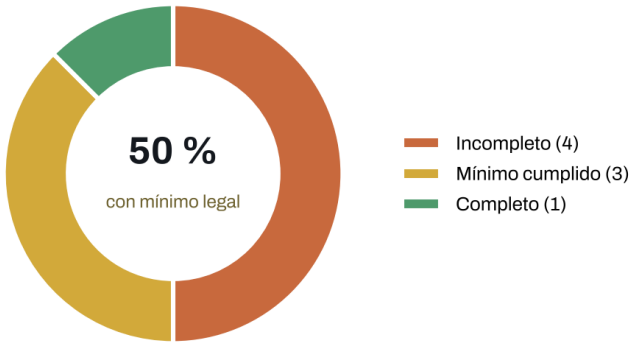


Figura 7. Estado del RAT del ejemplo ficticio: 8 actividades, 50 % con el mínimo legal cumplido.

Estado	Significado	Qué hacer
Incompleto	Falta al menos un elemento del art. 38 RGLOPDP	Prioridad: es un incumplimiento formal
Mínimo cumplido	Tiene el mínimo legal, pero hay observaciones de buena práctica	Atender observaciones en el plan
Completo	Mínimo legal y buenas prácticas	Mantener y revisar en la fecha prevista

ERROR FRECUENTE
Agrupar todo en una actividad «Gestión de clientes». Mezcla finalidades con bases y plazos distintos (facturación por obligación legal, publicidad por consentimiento) y vuelve imposible justificar cada una.

CÓMO DECIRLO AL CLIENTE
«El RAT es el inventario oficial de lo que su empresa hace con datos personales. Es lo primero que pedirá la Superintendencia y es la base de todos los demás documentos.»

6.3 Herramienta 04 · Evaluación de impacto

Qué es	Asistente de cinco pasos: necesidad, descripción, necesidad y proporcionalidad, matriz de riesgos con medidas, conclusión e informe con el contenido del art. 32 RGLOPDP.
Por qué	Es obligatoria, previa al tratamiento y se presenta ante la SPDP cuando hay perfiles automatizados con efectos jurídicos, gran escala de categorías especiales o datos penales, u observación sistemática a gran escala de zonas públicas (art. 42 LOPDP; arts. 31 y 32 RGLOPDP).

Cuándo	Antes de iniciar o modificar un tratamiento de alto riesgo. El RAT indica qué actividades la requieren.
Entregable	Informe de evaluación de impacto y matriz de riesgos.

1 ¿Es obligatoria?

Responda los supuestos del art. 42, la normativa especial (biométricos, inteligencia artificial, interés legítimo con NNA) y los indicadores de alto riesgo. Resultado: obligatoria, recomendada o no requerida.

2 Descripción sistemática

Finalidades, operaciones, datos, titulares y volumen, sistemas y flujos, terceros.

3 Necesidad y proporcionalidad

Diez criterios: base, finalidad, necesidad (¿hay una alternativa menos invasiva?), minimización, conservación, exactitud, información, derechos, encargados, transferencias.

4 Riesgos y medidas

Por escenario: dimensión, amenaza, vulnerabilidad, consecuencias para el titular, impacto y probabilidad (1 a 5), medidas y riesgo residual.

5 Conclusión

Umbral de aceptación (apetito al riesgo), dictamen y plan. Copie el informe a Word y la matriz a Excel.

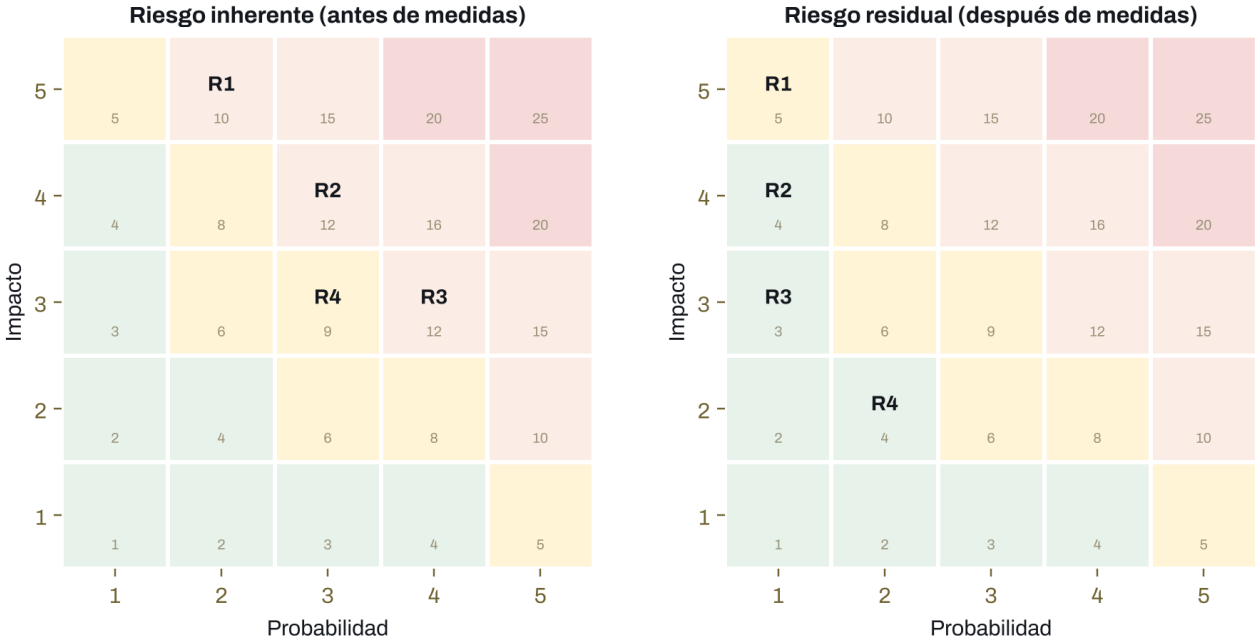


Figura 8. Matriz de riesgo del ejemplo (control de asistencia con huella): las medidas llevan los cuatro riesgos de nivel Alto a Medio y Bajo.

CONCEPTO CLAVE

Riesgo inherente es el riesgo antes de las medidas; **riesgo residual** es el que queda después. La evaluación de impacto demuestra que las medidas llevan el residual por debajo del umbral aceptado por la organización.

ERROR FRECUENTE

Calificar bajo un riesgo de impacto muy alto porque su probabilidad es baja. La guía de la SPDP advierte que las matrices pueden distorsionar estos casos; el asistente lo señala.

6.4 Herramienta 02 · Kit de plantillas

Qué es	Generador de documentos: política de privacidad, avisos (formulario, videovigilancia, correo), contrato de encargo, cláusulas de consentimiento y designación del DPD. Se completan los datos una vez y se aplican a todas las plantillas.
Por qué	Cumple el deber de información (art. 12 LOPDP), formaliza a los encargados (art. 41 RGLOPDP; no hacerlo es infracción grave, art. 68 num. 9 LOPDP) y documenta consentimientos y la designación del DPD (Res. 0006 y 0028).
Cuándo	Después del RAT: las finalidades, bases y plazos de la política salen de él.
Entregable	Documentos en Word con firma de responsabilidad.

1. **Datos generales**
   Razón social, RUC, correo de atención al titular (un buzón institucional, no el personal del DPD), datos del DPD registrado.
2. **Política desde el RAT**
   Traslade cada actividad: finalidad, base, plazo, destinatarios y transferencias.
3. **Avisos por punto de recolección**
   Un aviso por formulario, letrero o canal, no uno genérico.
4. **Contratos de encargo**
   Uno por cada encargado listado en el RAT, con los contenidos del art. 41 RGLOPDP.
5. **Consentimientos solo donde corresponde**
   Úselos cuando la base sea el consentimiento; no los pida para lo que se basa en contrato u obligación legal.

ERROR FRECUENTE

Pedir consentimiento para todo «por si acaso». Si el titular lo revoca y el tratamiento sigue siendo necesario, la cláusula queda engañosa. Identifique la base correcta en el RAT.

6.5 Herramienta 03 · Kit de vulneraciones

Qué es	Protocolo de respuesta, bitácora de incidentes y modelos de comunicación del encargado al responsable, a la SPDP y a los titulares, con calculadora de plazos y evaluación orientativa del riesgo.
Por qué	La notificación es obligatoria y con plazos cortos: el encargado comunica al responsable en máximo 2 días y el responsable notifica a la SPDP en el término de 5 días por el SISPDP (LOPDP art. 43; Res. SPDP-SPD-2026-0040-R). Desde mayo de 2026 también se notifica al CSIRT.
Cuándo	El protocolo se aprueba antes del incidente; el asistente se usa en las primeras horas.
Entregable	Protocolo aprobado, bitácora y notificaciones con constancia.

1. **Contener**
   Aislar, revocar accesos, recuperar lo enviado por error. Registrar la hora en que se tuvo constancia: desde allí corren los plazos.
2. **Evaluar**
   Causales del art. 24 RGLOPDP y factores de gravedad: datos sensibles, financieros, NNA, volumen, irreversibilidad.

3 **Notificar**

Encargado al responsable (2 días), responsable a la SPDP (5 días hábiles, SISPDP), ARCOTEL y CSIRT, y titulares cuando corresponda.

4 **Documentar**

Bitácora completa, se notifique o no, con la justificación de cada decisión.

ATENCIÓN

El plazo exacto de comunicación a los titulares y el canal del CSIRT están marcados como **puntos abiertos** en el kit: verifíquelos en el texto oficial antes de usarlos con un cliente.

6.6 Herramienta 07 · Evaluación de gran escala

Qué es	Asistente instructivo que califica cada tratamiento: primero los casos de calificación directa (RGLOPDP art. 4 num. 7 y art. 14 de la Res. SPDP-SPD-2026-0005-R) y luego el Modelo Técnico de Gran Escala, con seis variables y umbral de 6 puntos.
Por qué	Si un tratamiento es de gran escala, el DPD y la evaluación de impacto previa son obligatorios, el cálculo debe constar en el RAT, se audita cada 12 meses y se elabora un informe anual (arts. 12 y 15 a 18). Es la forma objetiva de responder «¿estoy obligado a tener DPD?».
Cuándo	Después del RAT, con cada actividad. Se recalcula al menos una vez al año y ante cambios sustanciales (arts. 6 y 13).
Entregable	Informe de gran escala firmado, con la evidencia de cada variable, y columnas para el RAT.

Variable	Qué dato pedir	Puntos
Titulares	Conteo de personas únicas del tratamiento en 12 meses	1 a 4
Volumen	Número de tipos de datos por persona (campos del formulario o la base)	0,5 a 3
Categorías	Si hay datos sensibles, de niñas, niños y adolescentes, salud, discapacidad, penales o grupos vulnerables	0,5 a 3
Frecuencia	Puntual, periódica o continua	0,5 a 2
Permanencia	Tiempo de uso activo (sin archivo ni bloqueo): ocasional, menos de 3 años, 3 años o más	0,5 a 2
Alcance	Local, nacional, o global y transfronterizo	1 a 3

1 **Pida la información**

Envíe la solicitud de información de la herramienta: conteos, campos, documentos, plazos de uso y cobertura. No necesita datos personales, solo cifras y descripciones.

2 **Paso A: calificación directa**

Si el tratamiento es de salud, biométrico, geolocalización, crédito, niñas, niños y adolescentes, videovigilancia de espacios públicos, transferencias sistemáticas o courier, es de gran escala sin cálculo.

3 **Paso B: seis variables**

Cada variable trae la pregunta, qué pedir, a quién, cómo contar y cómo explicarlo. Registre la fuente de cada dato.

4 **Lea el resultado**

6 puntos o más: gran escala. La herramienta advierte si el resultado está a menos de un punto del umbral.

5 **Documente y explique**

Copie el informe a Word y las columnas al RAT. Use el guion para la gerencia.

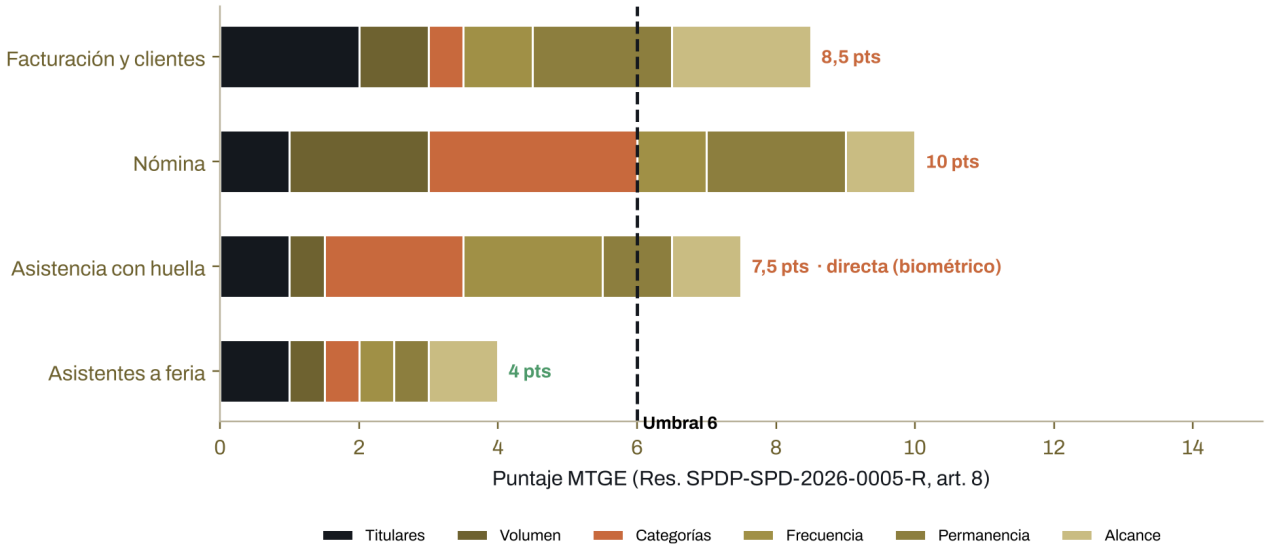


Figura 9. Puntaje MTGE de cuatro tratamientos del ejemplo ficticio. Tres superan el umbral; la asistencia con huella además es de calificación directa.

CONCEPTO CLAVE

La gran escala se mide **por tratamiento**, no por empresa. Una pyme puede tener tratamientos de gran escala y una gran empresa, tratamientos que no lo son.

ATENCIÓN

El umbral se alcanza con facilidad: un tratamiento con pocos datos básicos suma 6,5 puntos si es prolongado y nacional. Aplique el modelo como está, documente cada dato y, si el resultado parece desproporcionado, el responsable puede consultar a la SPDP; su respuesta es obligatoria para quien consulta (RGLOPDP art. 53). La permanencia cuenta el uso activo, no el plazo de archivo.

CÓMO DECIRLO AL CLIENTE

«La Superintendencia mide la gran escala con seis factores. Su facturación suma 8,5 puntos y el límite es 6. No es una sanción: significa que la ley le exige un delegado registrado, una evaluación de riesgos previa y una auditoría anual.»

6.7 Herramienta 06 · Calculadora de honorarios

Qué es	Calculadora con seis pestañas: cliente, volumen de negocio, volumen de tratamiento (MTGE), estimación técnica, comparar y decidir, y proforma de servicios con valores sugeridos, IVA y firma.
Por qué	Cotizar sin método lleva a cobrar de menos a las pymes con muchos datos o de más a las que no pueden pagar. La herramienta da un rango defendible y argumentos de valor honestos para el cliente.
Cuándo	Después de la primera reunión, antes de enviar la propuesta de evaluación o la de control.
Entregable	Proforma en Word con evaluación inicial, adecuación y control mensual: subtotal sin IVA, IVA y total.

1 **Datos del cliente**

Ventas del ejercicio anterior sin IVA, trabajadores, sector, actividades y encargados del RAT.

2 **Tres métodos**

Revise el resultado por volumen de negocio, por volumen de tratamiento y por horas. Ajuste horas si conoce mejor el caso.

3 **Decida**

Lea la mediana, el rango y las advertencias. Elija el método base. Considere paquetes, bolsa de horas o la comparación con un DPD interno.

4 **Proforma**

Marque servicios, revise valores sugeridos, agregue la multa estimada de la herramienta 05 para el argumento de inversión, complete condiciones y firma.

5 **Neto real**

Revise, solo para usted, lo que recibirá después de las retenciones de renta e IVA.

ERROR FRECUENTE

Presentar el ahorro frente a un DPD interno a tiempo completo como si fuera equivalente. La herramienta lo explica como lo que es: la dedicación que el cliente realmente necesita frente a un cargo completo.

CAPÍTULO 7

Áreas de tratamiento: cómo explicarlas

El RAT organiza las actividades por macroprocesos; el diagnóstico de madurez, por dominios de obligaciones. El DPD debe saber explicar ambas lecturas y cómo se conectan.

7.1 Macroprocesos del RAT

Macroproceso	Actividades típicas	Datos frecuentes	Base habitual	Riesgo a vigilar
Gestión de personas	Selección, nómina, asistencia, salud ocupacional	Identificación, bancarios, cargas familiares (NNA), salud, biométricos	Obligación legal; contrato	Datos de salud y biométricos; récord policial de postulantes
Clientes y ventas	Facturación, atención, cobranza, fidelización	Identificación, contacto, financieros	Contrato; obligación legal tributaria	Finalidades mezcladas con publicidad
Servicio principal	Historias clínicas, gestión académica, pólizas	Salud, NNA, financieros	Contrato; obligación legal	Gran escala de categorías especiales: evaluación de impacto
Proveedores y compras	Contratación, pagos	Contacto de personas naturales y representantes	Contrato	Encargados sin contrato de encargo
Marketing y comunicación	Publicidad, redes sociales, eventos	Contacto, imagen, preferencias	Consentimiento; interés legítimo con ponderación	Perfiles; listas sin consentimiento
Finanzas y cobranza	Gestión de cartera	Financieros, crediticios	Contrato; interés legítimo	Comunicación indebida a terceros
Seguridad física	Videovigilancia, control de acceso	Imagen, biométricos	Interés legítimo	Observación de zonas públicas; plazos de conservación
Tecnología y sistemas	Correo, nube, respaldos, registros	Todos los anteriores	La de cada actividad	Transferencias internacionales; vulneraciones
Legal y cumplimiento	Atención de derechos, requerimientos de autoridades	Identificación, expedientes	Obligación legal	Plazos de respuesta

7.2 Dominios del diagnóstico de madurez

Dominio	Qué significa	Cómo se ve en nivel 3 (Implementado)	Herramienta
Gobierno	La dirección asume la protección de datos como responsabilidad propia	Política interna aprobada, roles asignados, reporte periódico	05
DPD (crítico)	La figura del DPD está analizada y, si corresponde, designada	Gran escala evaluada; DPD registrado ante la SPDP con funciones y acceso a la dirección	07, 02
RAT (crítico)	La organización sabe qué datos trata	RAT con el mínimo legal, revisado y con bases inscritas	01
Licitud (crítico)	Cada tratamiento tiene su base legitimadora	Bases por actividad; consentimientos verificables; ponderación del interés legítimo	01, 02

Dominio	Qué significa	Cómo se ve en nivel 3 (Implementado)	Herramienta
Transparencia	Los titulares saben qué se hace con sus datos	Política publicada y avisos en cada punto de recolección	02
Derechos	Los titulares pueden ejercer sus derechos	Canal, procedimiento y registro de solicitudes con plazos	02
Encargados (crítico)	Los terceros que tratan datos están controlados	Inventario de encargados y contratos del art. 41 firmados	02
Seguridad (crítico)	Los datos están protegidos según su riesgo	Análisis de riesgos documentado, accesos por rol, respaldos probados	04
Evaluación de impacto	Los tratamientos de alto riesgo se evalúan antes	Evaluaciones previas; privacidad desde el diseño en proyectos	04
Vulneraciones (crítico)	La organización responde a incidentes en plazo	Protocolo aprobado, canal interno, bitácora, plazos conocidos	03
Transferencias	Los datos fuera del Ecuador tienen garantías	Servicios en el exterior identificados y garantías documentadas	01
Cultura	El personal sabe proteger datos	Capacitación al ingreso y periódica; compromisos de confidencialidad	Plan de capacitación

CONCEPTO CLAVE

Los dominios **críticos** pesan el doble en el índice porque su incumplimiento tiene mayor exposición sancionatoria o es la base del resto. Es un criterio propio del kit: la SPDP no ha emitido un modelo oficial de madurez.

CAPÍTULO 8

El informe a la gerencia

Primero se entrega el informe de evaluación general, con todos sus soportes; después se presenta en una reunión breve, centrada en decisiones.

8.1 Estructura del informe de evaluación general

Sección	Contenido	Fuente
1. Resumen ejecutivo (1 página)	Nivel de madurez, tres hallazgos principales, exposición económica y tres decisiones que se solicitan	05
2. Alcance y metodología	Procesos evaluados, entrevistas, documentos revisados, herramientas y normas aplicadas	Propuesta de evaluación
3. Resultado de madurez	Índice, radar, puntaje por dominio y lectura de cada nivel	05
4. Inventario de tratamientos	Número de actividades, estados, actividades de riesgo alto, transferencias internacionales	01
5. Riesgos y evaluaciones de impacto	Tratamientos que requieren evaluación, mapa de riesgo residual	04
6. Exposición económica y apetito al riesgo	Multa estimada sin acción y con plan, riesgo anual esperado, comparación con el apetito	05
7. Plan de acción	Acciones priorizadas con responsable, fecha y costo estimado	05 y anexos
8. Decisiones solicitadas	Aprobación del plan, presupuesto, designación de DPD, aprobación de la política interna	—
Anexos	RAT, informes de evaluación de impacto, documentos adecuados, matriz de soportes	01 a 04

8.2 Matriz de soportes

Cada cifra del informe debe tener un soporte verificable. Esta matriz se adjunta como anexo y es la que respalda el informe ante la gerencia y ante la SPDP.

Dato del informe	Soporte o evidencia	Quién lo provee
Índice de madurez y puntaje por dominio	Cuestionario respondido con comentarios de evidencia; documentos revisados	DPD con cada área
Volumen de negocio	Estado de resultados o declaración de impuesto a la renta del ejercicio anterior	Contabilidad
Número de actividades y estados	RAT en Excel con fecha y firma	DPD y dueños de procesos
Tratamientos de gran escala	Informe de la herramienta 07 con conteos de titulares, campos y evidencia de cada variable	DPD, sistemas y dueños de procesos
Encargados sin contrato	Listado de proveedores con acceso a datos y contratos vigentes	Compras o legal
Transferencias internacionales	Contratos o términos de servicio de proveedores en la nube	TI
Riesgos residuales	Matriz de riesgos e informes de evaluación de impacto	DPD y TI
Capacidad y tolerancia al riesgo	Acta o correo de la gerencia que las fija	Gerencia
Incidentes	Bitácora de vulneraciones	DPD

Dato del informe	Soporte o evidencia	Quién lo provee
Capacitación	Registros de asistencia y evaluaciones	Talento humano

8.3 La presentación oral (20 minutos)

1. **Un mensaje por gráfico**
   Radar (dónde estamos), multa estimada (cuánto arriesgamos), plan (qué hacemos). No más de tres gráficos.
2. **Hallazgos en lenguaje de negocio**
   «El proveedor de nómina no tiene contrato de encargo: es una infracción grave» es más claro que citar el art. 41 primero.
3. **Decisiones concretas**
   Cierre con tres decisiones, cada una con costo, responsable y fecha.
4. **Acta**
   Registre lo decidido. El acta es, a su vez, evidencia de responsabilidad proactiva.

CÓMO DECIRLO AL CLIENTE

«Hoy estamos en nivel Inicial. Las carencias más costosas son los contratos con proveedores y el protocolo de incidentes. Les pido aprobar tres decisiones: el plan de seis meses, la firma de los contratos de encargo y la designación de un responsable interno.»

8.4 Carpeta de evidencias

Carpeta	Contenido
01-Diagnóstico	Informe de madurez, cuestionario, matriz de soportes
02-RAT	RAT vigente y versiones anteriores, constancia de inscripción en el Registro Nacional
03-Riesgos	Matriz de riesgos, informes de evaluación de impacto y constancias de presentación
04-Documentos	Política, avisos, contratos de encargo firmados, consentimientos, designación del DPD
05-Incidentes	Protocolo aprobado, bitácora, notificaciones y constancias del SISPDP
06-Derechos	Registro de solicitudes y respuestas
07-Capacitación	Programas, asistencia, evaluaciones
08-Gerencia	Informes, actas y decisiones

CAPÍTULO 9

Control y mejora continua

El cumplimiento se degrada si nadie lo mide. El control convierte el proyecto en una práctica estable y es la base de la propuesta de servicio continuo.

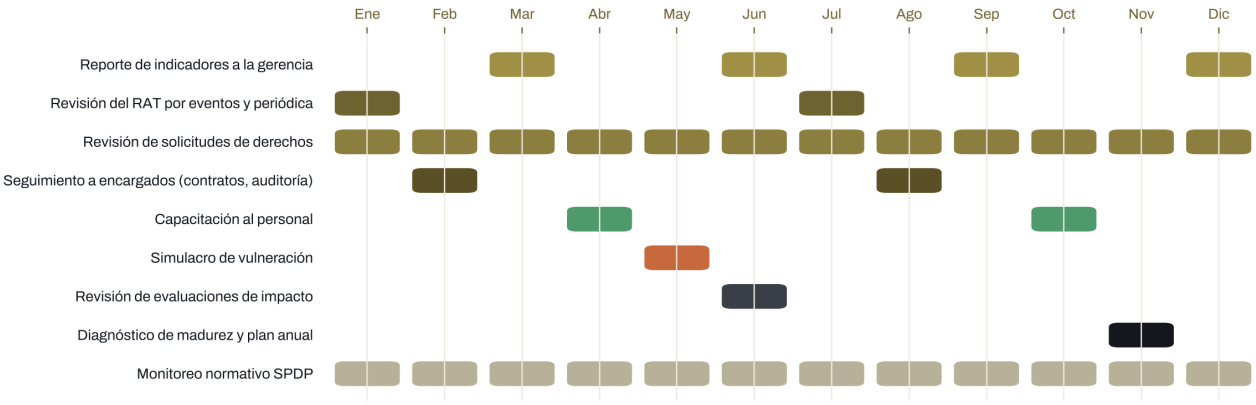


Figura 10. Calendario anual orientativo de actividades del DPD (criterio propio).

9.1 Indicadores para la gerencia

Indicador	Fórmula	Meta orientativa*
Actividades con mínimo legal	Actividades en estado Mínimo cumplido o Completo / total del RAT	100 %
Encargados con contrato	Encargados con contrato del art. 41 / total de encargados	100 %
Solicitudes de derechos en plazo	Respondidas en plazo / recibidas	100 %
Personal capacitado	Capacitados en el año / total de personal	≥ 90 %
Vulneraciones notificadas en plazo	Notificadas en plazo / notificables	100 %
Índice de madurez	Resultado anual de la herramienta 05	≥ 2,8 (Implementado)

* Criterio propio; ajustar con la gerencia.

CAPÍTULO 10

Normas ISO para el ejercicio del DPD

La LOPDP no exige certificaciones ISO. Pero las normas ISO ofrecen métodos probados para cumplirla y, sobre todo, para demostrarlo.

QUÉ DICE LA NORMA

La SPDP tiene competencia para emitir normativa sobre códigos de conducta y mecanismos de certificación (LOPDP art. 76 num. 5), y su plan regulatorio prevé un reglamento de certificaciones y sellos. Verifique su estado antes de ofrecer una certificación como prueba de cumplimiento ante la autoridad.



Figura 11. Normas ISO por nivel de prioridad para el ejercicio del DPD (criterio propio).

10.1 Indispensables para un buen ejercicio

Norma	Qué es	Relación con la LOPDP
ISO/IEC 27701:2025	Sistema de gestión de la privacidad. Desde la edición publicada el 14 de octubre de 2025 es una norma **independiente**: ya no exige tener ISO/IEC 27001 para certificarse.	Estructura todo el programa: roles, RAT, derechos, encargados, evaluación de impacto. Es la norma que más se acerca al rol del DPD.
ISO/IEC 27001:2022	Sistema de gestión de seguridad de la información y su anexo de controles.	Da contenido a las medidas técnicas y organizativas (art. 38 num. 9 RGLOPDP) y al análisis de riesgos (art. 40 LOPDP).
ISO/IEC 29100	Marco de privacidad: terminología, actores, principios.	Lenguaje común con TI y con auditores; ordena el inventario.
ISO/IEC 29134	Directrices para la evaluación de impacto en la privacidad.	Metodología de referencia para las evaluaciones del art. 42 LOPDP.

10.2 Recomendadas y según el caso

Norma	Cuándo usarla
ISO/IEC 27002:2022	Guía de implementación de los controles de seguridad.
ISO/IEC 27005 · ISO 31000	Metodología de gestión de riesgos; complementa la guía de riesgos de la SPDP.

Norma	Cuándo usarla
ISO/IEC 27035	Gestión de incidentes; sostiene el protocolo de vulneraciones.
ISO/IEC 29151	Controles específicos para la protección de datos personales.
ISO/IEC 27018	Si el cliente o sus encargados procesan datos en la nube pública.
ISO/IEC 29184	Diseño de avisos de privacidad y consentimiento en línea.
ISO/IEC 27560	Estructura de los registros de consentimiento.
ISO/IEC 42001	Sistemas de gestión de inteligencia artificial; útil frente a la norma de IA de la SPDP.
ISO 22301	Continuidad del negocio, cuando la disponibilidad de los datos es crítica.

10.3 Ruta de implementación sugerida

1. **Meses 0 a 6: cumplimiento LOPDP**
   Herramientas del kit. Use ISO/IEC 29100 y 29134 como guía metodológica, sin certificar.
2. **Meses 6 a 18: sistema de gestión**
   Implemente ISO/IEC 27701:2025 sobre lo construido: el RAT, las evaluaciones y los procedimientos ya son la mayor parte. Si el cliente necesita certificar seguridad, integre ISO/IEC 27001.
3. **Certificación**
   Solo cuando la exijan clientes, licitaciones o el sector, o cuando la SPDP reconozca certificaciones como evidencia.

BUENA PRÁCTICA

Para el DPD: una formación de implementador o auditor líder en ISO/IEC 27701 y conocimientos de ISO/IEC 27001 complementan el programa profesionalizante y diferencian el servicio.

CAPÍTULO 11

Recomendaciones para el ejercicio del DPD en Ecuador

Aspectos que no están en las herramientas, pero que determinan la calidad y la seguridad jurídica del ejercicio profesional.

Aspecto	Recomendación
Independencia	El DPD asesora y supervisa de forma independiente (art. 48 LOPDP). No asuma funciones que lo pongan en conflicto: no decida finalidades ni administre los sistemas que supervisa.
Requisitos y registro	Verifique los requisitos vigentes de la Res. SPDP-SPD-2025-0028-R y el art. 55 RGLOPDP. La SPDP aclaró en noviembre de 2025 que el programa profesionalizante no equivale a un título de tercer nivel.
Su propio cumplimiento	Como DPD externo usted es encargado de los datos de sus clientes: firme contrato de encargo y confidencialidad, y aplique a su despacho las mismas herramientas.
Uso de inteligencia artificial	Si usa herramientas de IA con datos de clientes, trabaje con datos anonimizados o seudonimizados y documente la evaluación del proveedor (transferencia internacional).
Firma de responsabilidad	Firme solo lo que verificó. Cada entregable del kit lleva bloque de firma: «elaborado por» y «revisado y aprobado por» el responsable.
Actualización normativa	La SPDP emite resoluciones con frecuencia. Revise mensualmente su repositorio de resoluciones y actualice la matriz BASE-LEGAL del kit.
Trabajo con TI	Establezca una relación de colaboración con el área de sistemas desde el primer día: el inventario y las medidas dependen de ella.
Documentar todo	Correos, actas y decisiones son evidencia de responsabilidad proactiva, propia y del cliente.
Límites del servicio	Deje por escrito lo que no incluye su servicio (por ejemplo, pruebas técnicas de seguridad) y recomiende especialistas.
Seguro y honorarios	Evalúe un seguro de responsabilidad profesional y fije honorarios por alcance cerrado en el diagnóstico y recurrentes en el control.

ANEXOS

Anexos

Anexo A · Lista de verificación de la primera visita

Verificar	Sí / No / Observación
¿Existe política de privacidad publicada?	
¿Los formularios web tienen aviso de privacidad?	
¿Hay cámaras? ¿Con letrero?	
¿Se usa reloj biométrico?	
¿Qué proveedores acceden a datos (nómina, contador, nube)?	
¿Tienen contratos de encargo?	
¿Existe un listado de bases de datos?	
¿Han tenido incidentes (pérdidas, envíos por error)?	
¿Alguien ha solicitado acceso o eliminación de sus datos?	
¿Está obligada a designar DPD?	
¿Número de trabajadores?	
¿Ingresos del ejercicio anterior disponibles?	

Anexo B · Guion de entrevista por área

1. ¿Qué procesos realiza su área? ¿Cuál es el más frecuente?
2. En cada proceso, ¿qué información de personas se solicita? ¿En qué formulario o canal?
3. ¿Para qué se usa esa información? ¿Se usa también para algo más?
4. ¿Dónde se guarda: sistema, nube, correo, hoja de cálculo, papel?
5. ¿Quién tiene acceso dentro y fuera de la empresa?
6. ¿Se envía a alguna entidad o proveedor? ¿Alguno está fuera del Ecuador?
7. ¿Cuánto tiempo se conserva? ¿Quién decide cuándo se elimina?
8. ¿Se toman decisiones automáticas o se elaboran perfiles con esa información?
9. ¿Ha ocurrido algún incidente con esos datos?
10. ¿Qué documento firma o recibe la persona cuando entrega sus datos?

Anexo C · Puntos que el DPD debe verificar en el texto oficial

Tema	Estado en el kit
Plazo de comunicación de vulneraciones a los titulares	La doctrina cita 3 días (art. 46 LOPDP); la norma técnica no fija plazo. Verificar.
Canal y plazo de notificación al CSIRT	Reforma del art. 43 (mayo 2026). Verificar.
Anexo I de la Res. SPDP-SPD-2025-0022-R	Fórmulas tomadas de un resumen profesional; sentido del PDI y pesos interpretados.
Escalas y anexo de la guía de riesgos (Res. 0003)	Cap. II referencial; el kit usa escalas propias.
Alcance de la evaluación de impacto en las normas de IA y biométricos	Leer textos completos.

Tema	Estado en el kit
Mecanismos de la norma general de transferencias (Res. 2026-0004)	Incorporar a las herramientas 01 y 05.
Reglamento de certificaciones y sellos	Verificar si fue expedido.
Alcance de «otros datos sensibles» en el art. 14.1 de la Res. 2026-0005	Podría calificar directamente todo tratamiento con datos sensibles. Documentar criterio o consultar.
Nube en el exterior y alcance «transfronterizo» (MTGE)	Precisar si basta el almacenamiento fuera del país.
Retenciones de IVA y de renta para sociedades	Verificar la tabla vigente del SRI.

MANTENIMIENTO DEL KIT

El kit se mantiene en un repositorio con una matriz de base legal y un historial de versiones. Cada actualización normativa se registra allí y se refleja en las herramientas y en esta guía.